

ISYS90090 · CYBERSECURITY MANAGEMENT

Week 7 · Policy

Policy management in cybersecurity. Presentations finish first, then we pick the Horizon case back up: scenes 10 to 13.

Tuesday 3pm to 5pm · Thursday 1pm to 3pm



Attendance

Login using your student.unimelb.edu.au email

While you wait, say hello to the people either side of you.

2:00

TIMER



Bull's Eye Model

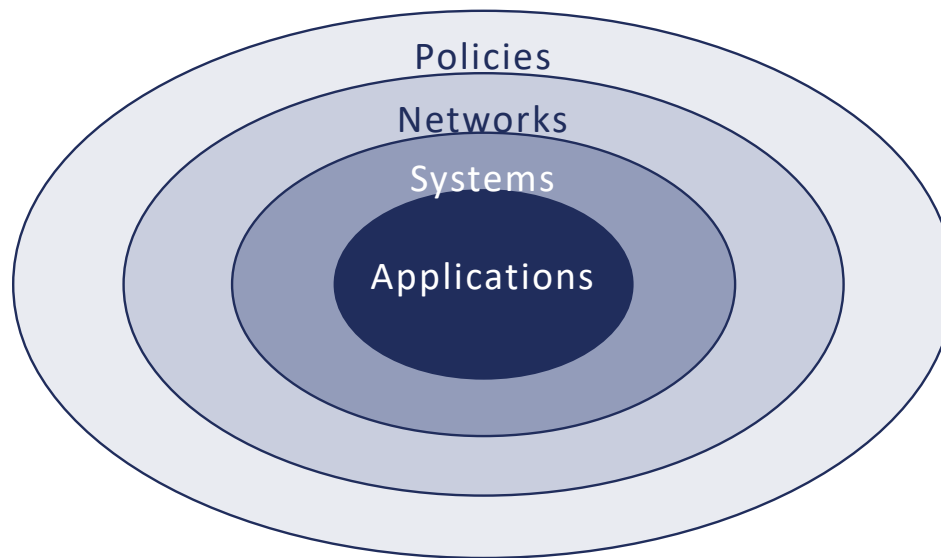


Figure 4-1. The Bull's-Eye Model (Whitman & Mattord).

WORK FROM THE OUTSIDE IN

■ Policies

Until sound and useable IT and information security policies are developed, communicated and enforced, no additional resources should be spent on other controls.

■ Networks

Until effective network controls are designed and deployed, all resources should go toward achieving this goal.

■ Systems

Then focus on the information, process and manufacturing systems — until there is assurance that all critical systems are configured and operated securely.

■ Applications

Only then move to assessing and remediating the security of the organisation's applications, most critical first.

For policies to be effective

READING

Policies must be properly disseminated

How would you disseminate a policy in an organisation?

COMPREHENSION

Policies must be understood by the target audience

How would you ensure that the policy has been understood?

COMPLIANCE

Policies must be agreed upon by the target audience

How would you ensure that employees agree to comply with the policy?

UNIFORM ENFORCEMENT

Policies must be uniformly enforced on the target audience

How would you ensure that the policies have been enforced?

Policies require constant modification and maintenance.

MANAGEMENT MUST DEFINE THREE TYPES OF POLICY

Enterprise information security program policy · Issue-specific information security policies · Systems-specific information security policies

Measuring Policy Quality

	Definition	Significance Why is it important?	Method of assessment How can policies be tested for it?	Discriminating power What does a 'good' policy look like vs a 'bad' policy?
Completeness	The extent to which the information security policy addresses all security requirements.	Organizations must ensure ALL of their security objectives and directives are met by the policy, i.e. there aren't any gaps or holes.	Map each explicit security objective and directive to particular policy statements.	Completeness depends on the number as well as the criticality of statements that address security objectives and directives.
Suitability	The extent to which the information security policy is appropriate for the organization.	Because every organization is different (org culture, legal, regulatory issues etc) requiring policies to have different characteristics.	May require multiple approaches. Explicit legal and regulatory requirements be mapped to specific policy statements. Suitability to org culture assessed by observing influence on security behaviors.	Notionally, a good policy will complement the organizational culture and effect positive change in security behavior. Also, where legal and regulatory issues are concerned it might be simply a matter of mapping requirements to policy statements.
Accuracy	The extent to which information security policy statements correctly address security requirements.	Vague/erroneous wording can leave org. open to liability, misleading and confusing employees etc.	Policy statements are reviewed by multiple stakeholders including senior management and legal professionals to determine accuracy.	A good policy will (predominantly) consist of statements that correctly address security requirements.
Interoperability	The extent to which information security policy interacts successfully with other organizational policies.	Org. policies should not contradict each other; wording and structure should be similar. Conflict/gaps may allow security breaches.	All org policies that influence or are influenced by security must be reviewed by multiple stakeholders including senior management and legal professionals to determine compatibility and gaps.	A good policy will match structure and wording (e.g. positive reinforcement vs prosecutorial) to support relevant policies in the organization.
Security	The appropriateness of the confidentiality, integrity and availability of the information security policy.	Disclosure of all or part of the policy to unauthorized recipients could be a security risk. However, restricted availability may inhibit compliance because of inadequate circulation.	Confidentiality and availability can be assessed by having security managers and a range of other stakeholders conduct a review of policy statements. The review would focus on potential impact of leakage and need-to-know.	A good policy will not have statements that can facilitate an attack or increase risk of attack to the organization. A good policy will not have statements that impose restrictions on circulation to those who need to know.

Measuring Policy Quality

	Definition	Significance Why is it important?	Method of assessment How can policies be tested for it?	Discriminating power What does a 'good' policy look like vs a 'bad' policy?
Analyzability	The extent to which information security policy can be methodically examined for deficiencies.	Organizations must be able to examine policy to identify deficiencies.	Policies can be tested for logical flow and modularity. Modular policies featuring a logical break down of topics are relatively easier to analyze than policies with no logic to their structure and spaghetti-like relationships with statements.	A good policy will be structured and worded to facilitate examination and location of a range of topics and statements such as particular risks and the countermeasures.
Stability	The extent to which the information security policy is designed to resist the impact of change.	Policies are frequently revised. Changes to policy should not introduce new and unanticipated problems.	Policies can be tested for logical flow and modularity. Impact of changes made to a logically structured policy are easier to anticipate and correct. Modular policies are more likely to contain or limit the impact of changes.	A good security policy will address security risks through multiple statements (high-level and specific) in case a statement is compromised.
Changeability	The extent to which information security policy can be adapted to changes in environment.	Policies are frequently revised to meet new regulations, standards or business processes. The ability of the policy to be changed is important.	Policies can be tested for logical flow and modularity. Modular policies are easier to change as there is a stronger likelihood that related statements will be in one section or location.	A good security policy is organized logically and systematically so necessary changes can be made efficiently and with minimal restructuring of the rest of the policy.
Testability	The extent to which the effectiveness of the information security policy can be determined (when changes occur).	Organizations must be able to identify issues with the security policy prior to deployment.	Policies can be tested for logical flow and modularity. Policy modules may be deployed without the need for the entire policy to be deployed.	A good policy can be deployed easily so feedback on its effectiveness can be generated quickly.

Discussion — what does a more deploy-able policy look like? Is it more modular, as opposed to spaghetti-like?

PART C · THE CASE

Horizon, scenes 10 to 13

Four scenes in one block. We left Anders at the end of scene 9.

Who is who in the case

AT HORIZON AUTOMOTIVE

Anders Svensson

Chief Executive Officer

Lena

VP Research and Development

Kurt

Director, IT Services

Gustav

HR Manager

Linus

VP Manufacturing

Lisa

Corporate Solicitor

Carl

Risk Assessor

Lars

Head of physical security

AROUND HORIZON

Karim

Independent information security consultant,
and an old friend of Anders

Emil

Former Horizon R&D engineer, now at FC
Design

Erik

Dealer in performance cars

Patrick Chau

Corporate intelligence consultant

THE THREAT

Oliver

Spymaster. A retired British intelligence agent
turned mercenary

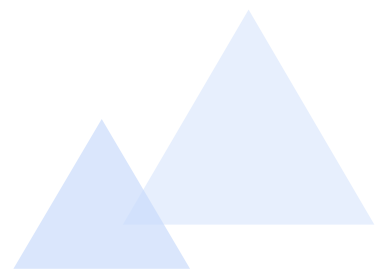
Jordan

Hacker

John

Representative of FC Design Automotive
Industries

The scenes are not in chronological order, and the case runs to scene 14.



Scene 10: Hamburg

1

Karim: what is the most valuable asset that sustains your competitive advantage?

2

Anders: the cars, of course. Each one is worth upwards of a million and a half US dollars.

3

Karim: but you are giving the cars away. Your primary asset is the capability to make cars your market will buy at the price you set.

4

What drives that is your specialised knowledge. It is in the engineers' heads, and it is embedded in the processes and in the specialised tools and techniques Horizon invented itself.

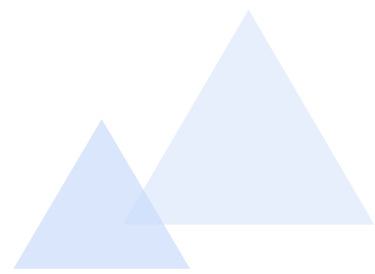
5

Why steal the designs then? They help FC Design's engineers understand in part how you build your cars. To build the NextGen car first they still needed Horizon engineers on the factory floor.

6

Karim: fix the leak, but look more broadly at people, process and technology rather than just technology.

Karim: it is the security of knowledge, not just information, and it is not limited to IT.



Scene 11: Sweden

- 1 Karim, over the network diagram: the first good thing is that R&D is completely segregated from the main network.
- 2 But the rest of the organisation has only one line of defence, the outside perimeter firewall, and it is a garden variety off the shelf product.
- 3 A castle strategy with one layer and a giant blind spot inside, because internal activity is not monitored at all. Other than that, standard anti-virus and passwords.
- 4 Karim: change the way you think about security before you change the infrastructure itself.
- 5 You have an intelligent and very resourceful adversary that is out to steal your capability rather than disrupt your IT services.
- 6 Karim: everything starts with risk. Until you know what you are defending against, you cannot develop an effective strategy.

Karim, on how the adversary knows Horizon's routines: they see things as they are, you see them as they should be.

Scene 12: the last risk assessment

Carl: security risks are managed like all other risks. We identify assets in a workshop with the security managers, estimate likelihood and impact, and sort by the product of the two. We meet periodically to reassess, as per best practice standards.

When did you conduct the last one? That would be three years ago.

How many assets did you identify? Assets? Well, one of course. Our IT systems.

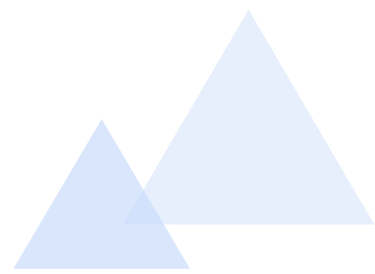
How many risks did you identify? About four or five. System failure, hacker attack, virus outbreak, natural disasters.

How do you estimate likelihood? We have a discussion, and I guess it is a gut feel thing.

And how do you estimate impact? We rate it low, medium or high depending on how we think the incident will play out.

Do you classify the sensitivity of information? No. We never felt the need.

Horizon has no way of classifying the sensitivity of information.



Scene 13: what happens

1

The lock on Karim's office door has been tampered with. Tiny dents and scuff marks around the keyhole. A break-in, or someone trying different keys to see which one fits.

2

Inside, someone has dropped a heavy binder on his desk. Printed on the cover: Information Security Policy.

3

He reads it, closes the front cover, and drops it on the floor with a loud thud.

4

He rings Anders. Where is the Information Security Policy? Anders: Umm, Kurt has it. How many copies are floating around? I have no idea. I only know of one.

5

He rings Lena, VP of Research and Development, and gets the same reply.

6

Karim: nobody but Kurt has access to it, it is unreadable in its current form, and the last version was three years ago. Might as well bury the policy in the ground.

Karim never reads a single policy statement before reaching that verdict.

The Policy Post-Mortem

Horizon has a policy, and everyone carried on exactly as before. Why, and what would you fix first?

Groups

One sheet per group.

Today

You are diagnosing a policy, not drafting one. No draft policy at the end.

30 min

Find three faults. Pick one to fix. Report back.

Official Security Policy versus Unofficial Security Policy. Policy frequently clashes with culture.

Every fault has three parts

Write all three, in this order

Part 1

What Karim found. Something he saw in the binder, or was told on the phone.

Part 2

What it costs Horizon. The business consequence.

Part 3

The name for it, from the lecture's conditions or attributes.

15 MIN

15:00

10 minutes

Three faults per group.

Worked example

The policy sits in one office and the CEO could not produce a copy. Horizon has no way to show anyone ever read it, so a dismissal on the strength of it would fail. That is a failure of dissemination and comprehension.

Pick one to fix

Which of your three faults do you fix first, and why can the other two wait?

Constraint

One revision cycle. One budget cycle. The staff Horizon already has.

Also say

Which fault you are letting go, and why it can wait.

7 MIN

7:00

7 minutes

One fix per group.

Your answer has to be about Horizon, not about policies in general.

Report back

Three groups. Ninety seconds each.

Tell us

The fault, the fix you chose, and the fix you let go.

Everyone else

Owes the reporting group one challenge.

Not needed

Slides, or a written answer. Keep it verbal.

7 MIN

7:00

7 minutes

I will pick three groups that found different faults.

Leave your three faults where they are. You do not need to tidy them up.

Thanks, See you next week.

